



Beata Zalewa

**OSINT - zobacz swoją firmę oczami
hakerów, zanim będzie za późno**



**Expert
Summit 2025**

All about Microsoft® technologies

ONLINE

Sala B

Godz. 13:00



techevents

0 mnie



Security Architect



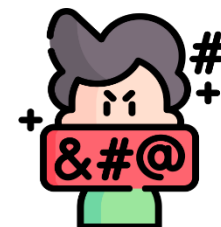
Consultant



Microsoft Certified Trainer



AI & Cybersecurity Practitioner



Developer



Freelancer



Azure @ ❤️



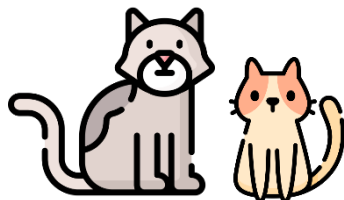
Google Cloud



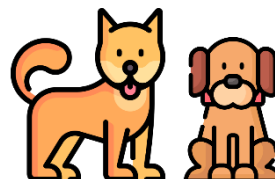
1 Maż



1 Córka



2 Koty



2 Psy



Kryminały



Fotografia

AKT I: ZWIERCIADŁO

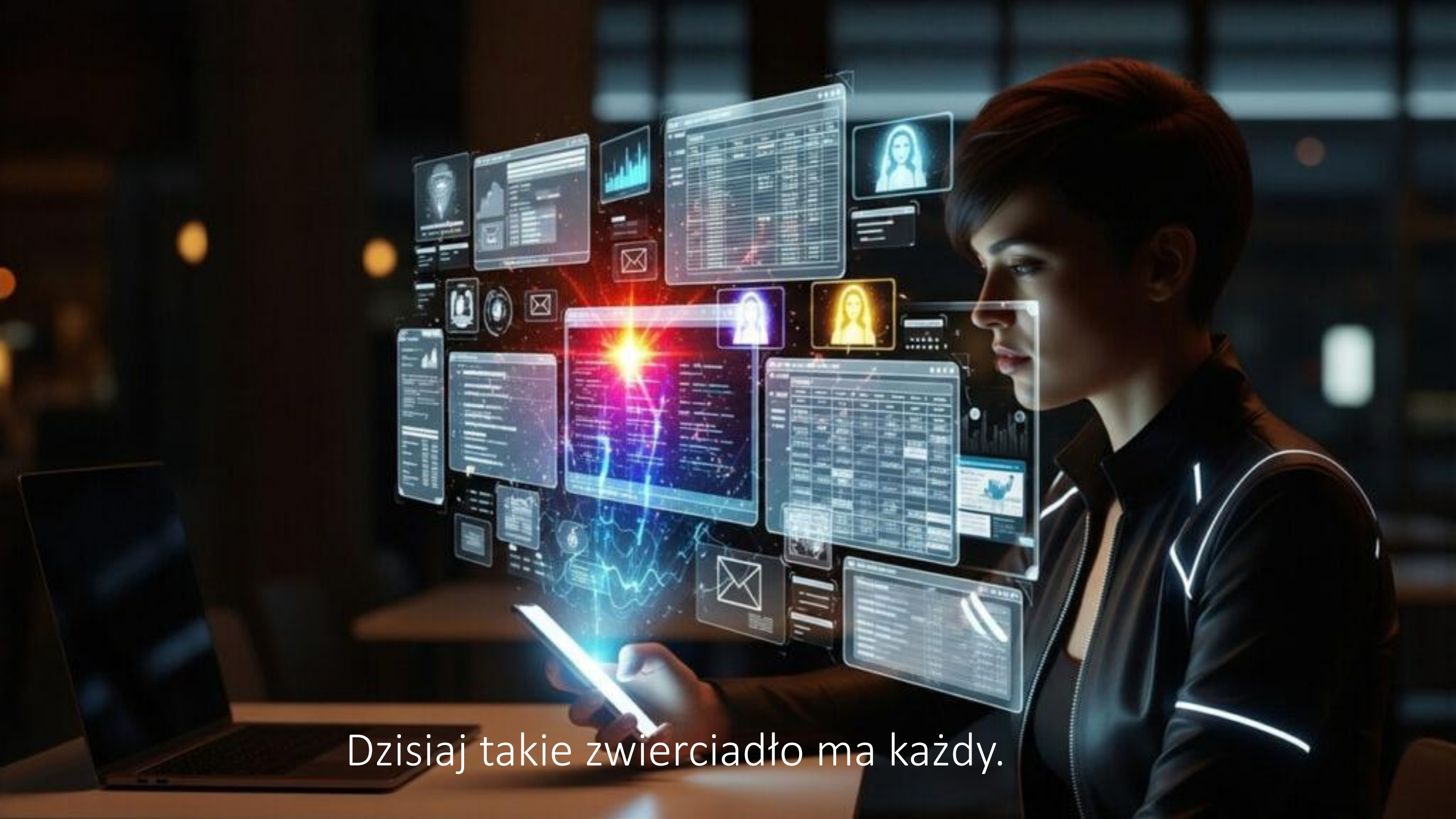


Pamiętacie taką bajkę z
dzieciństwa...?





...jak zła królowa mogła sprawdzić, co robi Królowna Śnieżka?



Dzisiaj takie zwierciadło ma każdy.

Każdy może sprawdzić kontrahenta.
Każdy może dokonać weryfikacji.

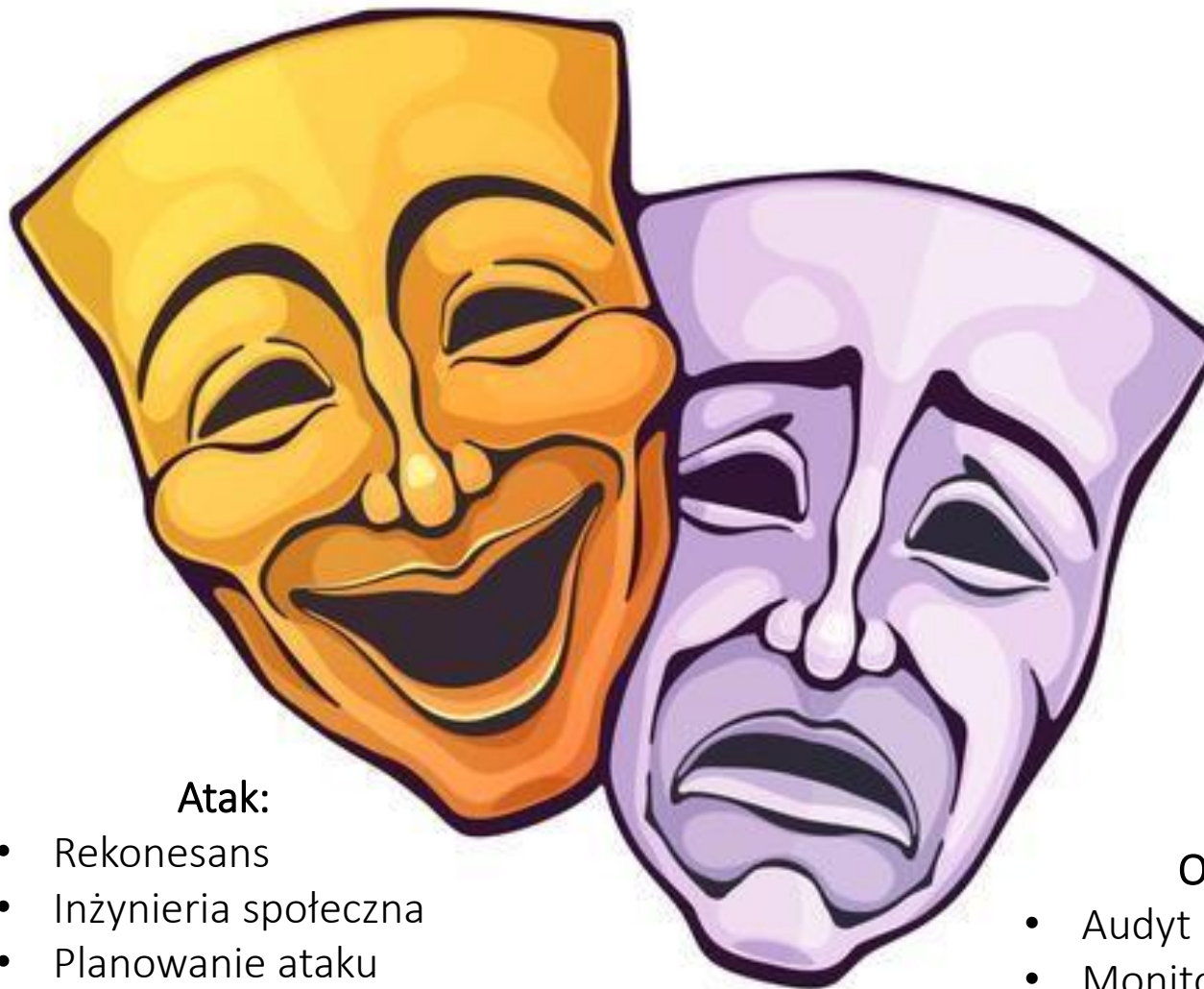




Obecnie każdy bit informacji jest potencjalnym ładunkiem wybuchowym.

Informacja może być wykorzystana do niszczenia tworzonego przez lata wizerunku firmy.





Atak:

- Rekonesans
- Inżynieria społeczna
- Planowanie ataku

Obrona:

- Audyt
- Monitorowanie
- Identyfikacja słabości

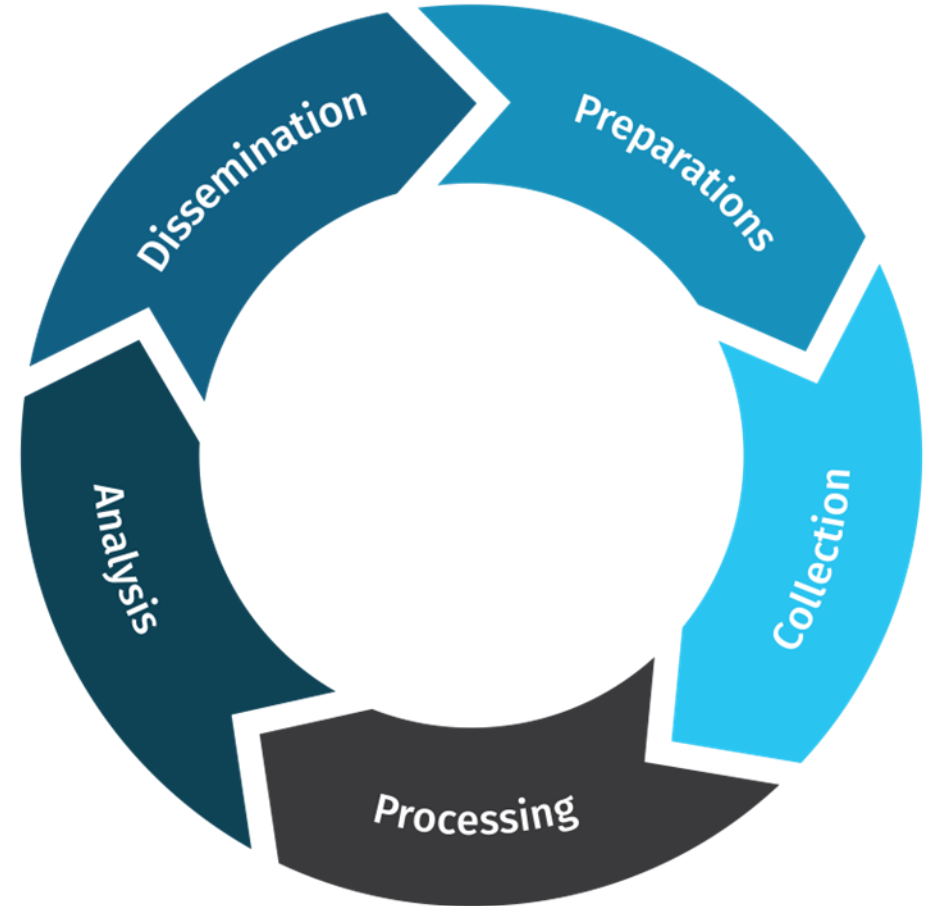
Czym naprawdę jest OSINT?

Sztuką znajdowania informacji, o których myślałeś, że są prywatne.

Proces zbierania i analizowania informacji z publicznie dostępnych źródeł w celu gotowej informacji wywiadowczej (intelligence).

OSINT – co to jest?

- OSINT oznacza Open Source Intelligence
- OSINT odnosi się do wywiadu opartego na jawnych źródłach informacji.
- Obejmuje zbieranie, analizowanie i wykorzystywanie danych dostępnych publicznie
- OSINT nie polega na uzyskiwaniu dostępu do informacji chronionych czy nielegalnych, lecz na analizie danych, które są otwarcie dostępne dla każdego.



OSINT

Krótką historia

OSINT, czyli wywiad oparty na jawnych źródłach, narodził się w Stanach Zjednoczonych w latach 40. XX wieku, podczas II Wojny Światowej.

W tamtym czasie zauważono, że wiele informacji **uznawanych za tajne** można **znaleźć w publicznie dostępnych** materiałach, takich jak dokumenty, prasa czy inne otwarte źródła.

Zamiast angażować szpiegów, wystarczyło te dane zebrać i odpowiednio przeanalizować.

OSINT

Krótką historia

Powołano więc specjalną jednostkę działającą w ramach amerykańskiej marynarki wojennej.

Warto podkreślić, że **OSINT nie polega na hakowaniu ani na uzyskiwaniu dostępu do zakazanych miejsc** – opiera się wyłącznie na analizie informacji dostępnych publicznie.

OSINT

- Pamiętaj, że w OSINT każde źródło informacji może być **wartościowe**.
- Mimo to, zawsze **weryfikuj dane** i podchodź do nich z odpowiednią dozą sceptycyzmu.
- Prawdziwy wywiad opiera się głównie na **analizie zebranych informacji**, a nie tylko na ich gromadzeniu.
- **A co z danymi pochodzącymi z wycieków znalezionych w Darknecie?**
To pytanie nie jest takie proste i wymaga szczególnego podejścia do tematu i rozwagi, zanim zaczniemy rozpowszechniać treści.

CELE OSINT

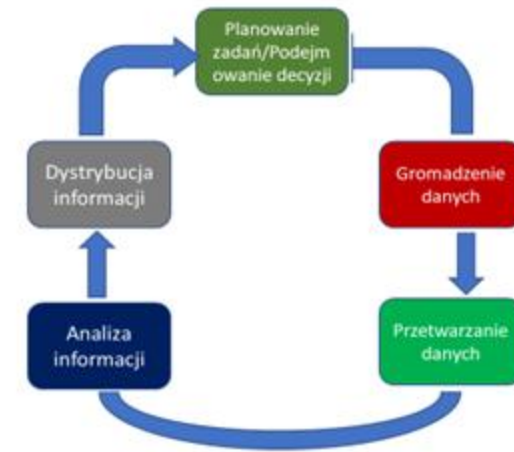
- **Wywiad dotyczący bezpieczeństwa i zagrożeń** - identyfikacja zagrożeń bezpieczeństwa poprzez analizę publicznych informacji o osobach i organizacjach.
- **Śledztwa** - prowadzenie śledztw w różnych sprawach poprzez zbieranie odpowiednich informacji.
- **Wywiad konkurencyjny** - gromadzenie informacji o konkurencji, trendach rynkowych, preferencjach.

CELE OSINT cd.

- **Zarządzanie reputacją** - monitorowanie i zarządzanie reputacją online osób, organizacji i marek.
- **Dziennikarstwo i badania** - wspieranie badań poprzez gromadzenie danych w celu odkrywania faktów, weryfikowania twierdzeń i dostarczania kontekstu.
- **Reagowanie na katastrofy i kryzysy** - ocena wpływu katastrof naturalnych, konfliktów lub kryzysów, aby ułatwić .skuteczną reakcję.

1. Planowanie i ukierunkowywanie

- Określenie celu
- Identyfikacja źródeł informacji
- Zdefiniowanie zakresu działań
- Dobór narzędzi i metod
- Ocena ryzyka i zgodności z prawem
- Przydzielenie zasobów
- Opracowywanie strategii badania i planu działania
- Dyskusje



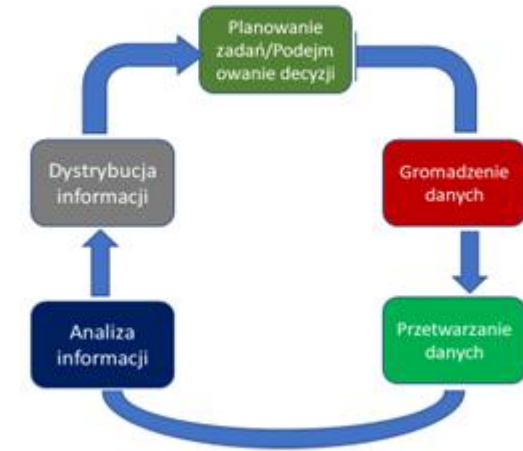
2. Zbieranie / gromadzenie danych

- Identyfikacja dostępnych źródeł
- Wykorzystanie narzędzi OSINT
- Zbieranie danych z mediów społecznościowych
- Analiza domen i infrastruktury sieciowej
- Zbieranie danych multimedialnych
- Monitorowanie Darknetu i forów
- Weryfikacja i filtrowanie danych



3. Przetwarzanie danych

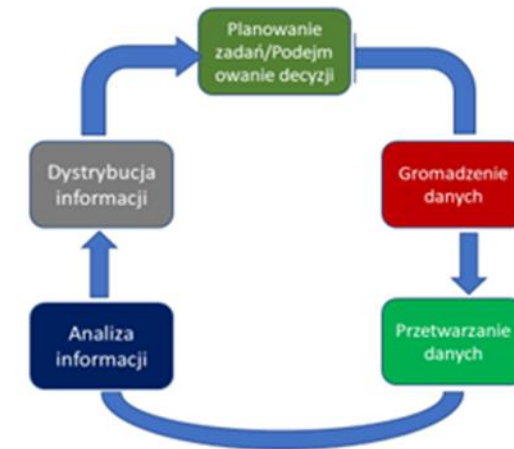
- Organizacja zebranych danych
- Konwersja danych do użytecznego formatu
- Analiza metadanych
- Filtrowanie i weryfikacja danych
- Łączenie danych z różnych źródeł
- Automatyzacja przetwarzania
- Identyfikacja wzorców i anomalii
- Tworzenie raportów i wizualizacji
- Zabezpieczenie przetworzonych danych



Skompilowanie zebranych danych w raporty wywiadowcze.

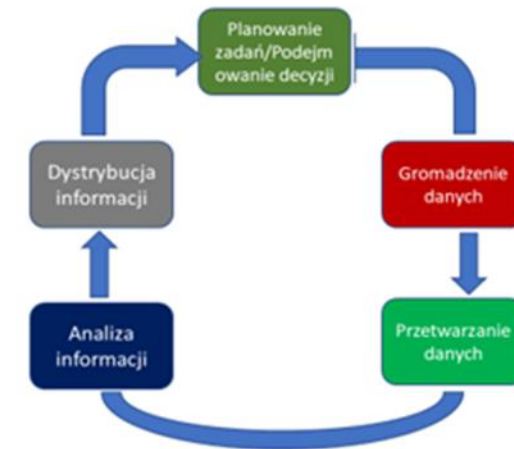
4. Analiza informacji

- Zrozumienie kontekstu
- Łączenie danych
- Identyfikacja wzorców i trendów
- Ocena wiarygodności informacji
- Priorytetyzacja danych
- Tworzenie hipotez
- Wizualizacja wyników
- Dokumentowanie wyników
- Ocena ryzyka i potencjalnych działań



5. Rozpowszechnianie/ dystrybucja informacji

- Przygotowanie raportu końcowego
- Dostosowanie formatu do odbiorcy
- Zabezpieczenie informacji
- Wybór kanałów dystrybucji
- Przekazanie informacji
- Zapewnienie możliwości dalszej analizy
- Zbieranie informacji zwrotnej
- Monitorowanie dalszego wykorzystania informacji



- Przekazanie analizy decydentowi
- Czekanie na opinię
- W razie potrzeby powtórzenie cyklu

Główni odbiorcy OSINT

- Służby wywiadowcze i agencje rządowe
- Prywatni detektywi
- Kancelarie prawne
- Pentesterzy
- Analitycy finansowi
- Ubezpieczyciele
- Firmy
- Firmy konsultingowe
- Dziennikarze śledczy itd.



Korporacje

- Ochrona i kontrola personelu
- Należyta staranność
- Śledztwa w sprawie oszustw
- Ryzyko łańcucha dostaw
- Ochrona aktywów
- Monitorowanie marki



Główne źródła OSINTu

- Identyfikatory osób
- Social media
- Artykuły informacyjne
- Raporty
- Witryny
- Blogi i fora internetowe
- Bazy danych

GŁÓWNE ŹRÓDŁA OSINTU



**MEDIA
SPOŁECZNOŚCIOWE**



**WITRYNY
INTERNETOWE**



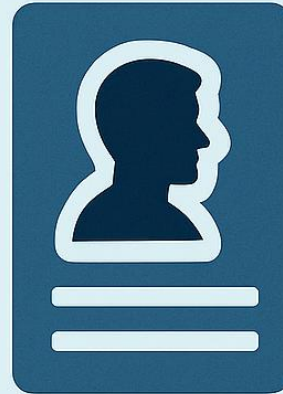
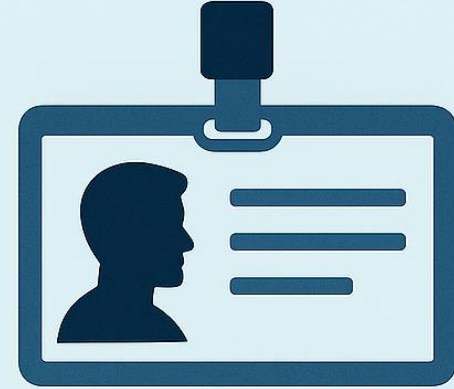
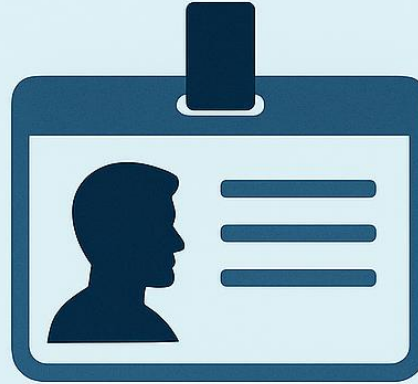
WYSZUKIWARKI



BAZY DANYCH

Identyfikatory osób

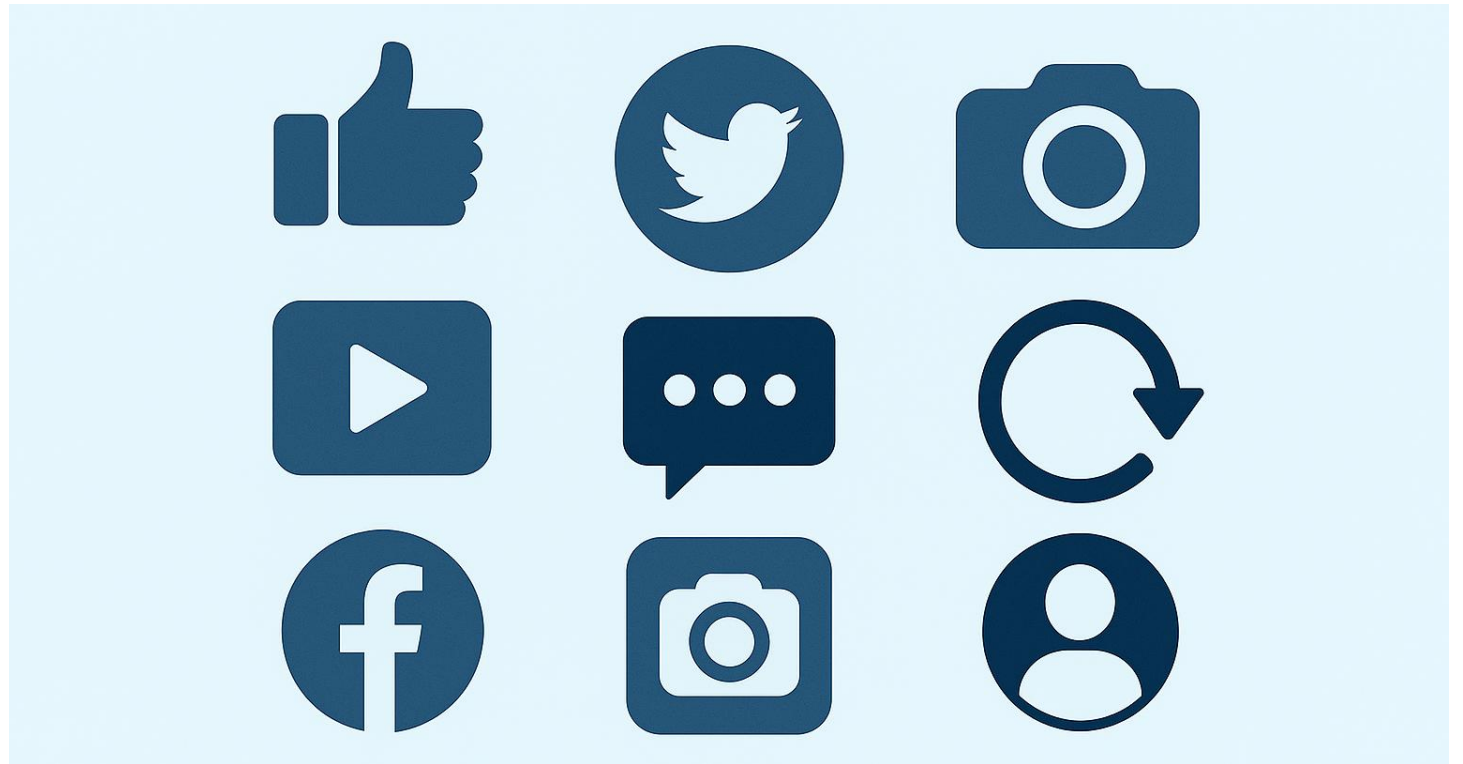
- Imiona
- Pseudonimy
- Adresy e-mail
- Numery telefonów
- Historia zatrudnienia
- Wykształcenie



Social media

Pozyskiwanie informacji z takich platform jak:

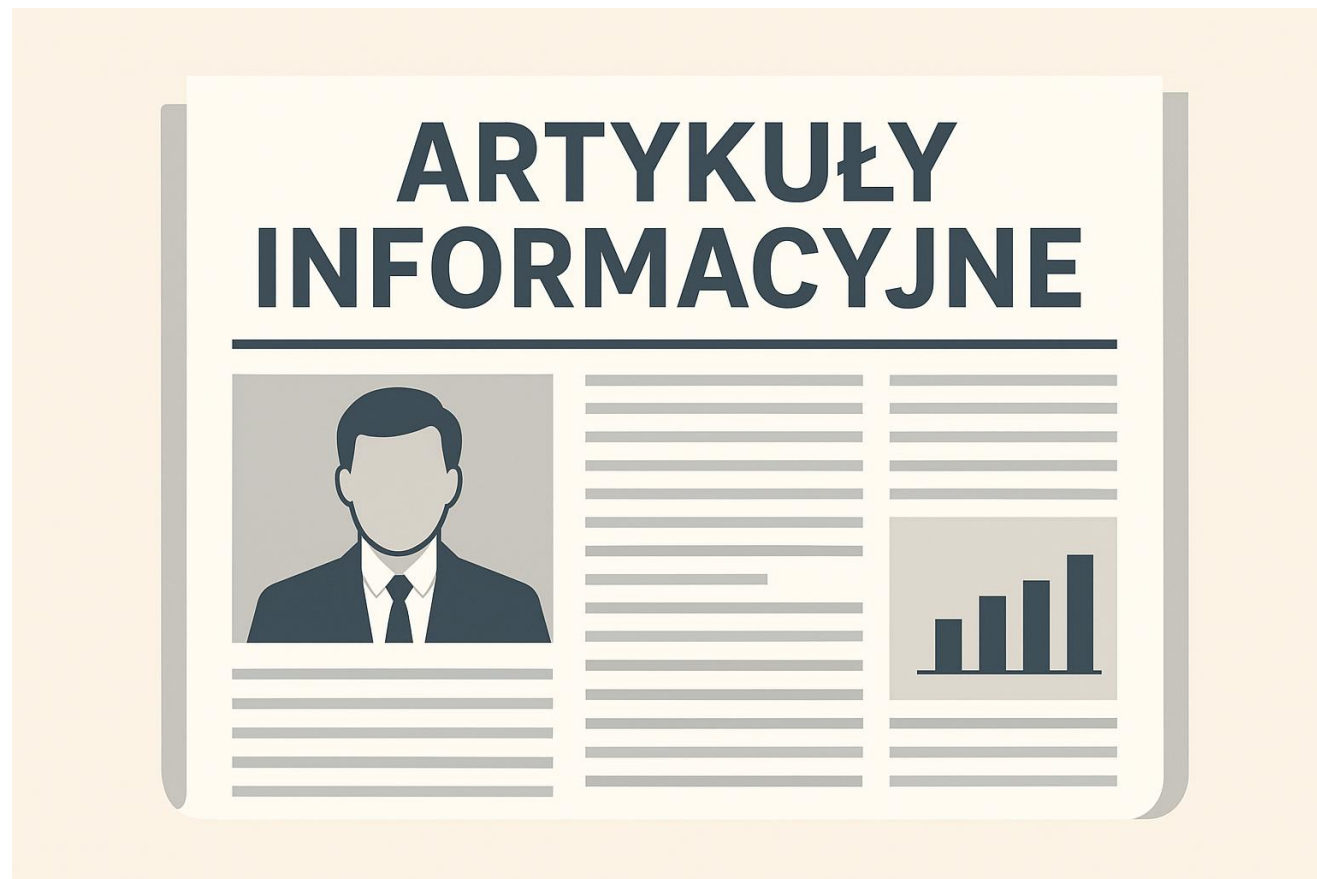
- Facebook
- X (dawny Twitter)
- Instagram
- LinkedIn
- TikTok
- inne



Artykuły informacyjne

Może to obejmować:

- tradycyjne serwisy informacyjne
- gazety internetowe
- inne źródła, w których relacjonowane są wiadomości i bieżące wydarzenia



Raporty

- Dokumenty
- Publikacje
- Dokumenty informacyjne
- Dane statystyczne
- Inne informacje publikowane przez agencje rządowe

RAPORTY



Blogi i fora internetowe

- Cenne spostrzeżenia
- Opinie
- Dyskusje i treści tworzone przez użytkowników na szeroki zakres tematów
- Tekst
- Obrazy
- Filmy
- Dokumenty
- Metadane
- Inne treści multimedialne





OSINT to nie tylko narzędzie atakujących.

To niezbędny element proaktywnej obrony każdej firmy.

Nawet tytani branży stają dziś w obliczu wrogów, którzy wykorzystują ich własną jawność



Techniki OSINT

- Wyszukiwanie informacji
- Analiza metadanych i geolokalizacji
- Wykorzystanie wyszukiwania obrazem do identyfikacji źródeł

<https://verificators.com/wyszukiwanie-informacji-osint-case-study/>

<https://rynekinformacji.pl/>

<https://www.support-online.pl/blog/bialy-wywiad-jak-osint-zmienia-i-analizuje-informacji-z-ogolnodostepnych-zrodel/>



AKT II: OCZAMI HAKERA



Jak Twój cyfrowy ślad staje się polem minowym?

Hakerzy spędzają 80% czasu na przygotowaniu.
Na Twoim terenie. Używając Twoich danych.



Niewinny post na LinkedIn



Copilot pozdrawia ;)

Co widzi użytkownik Linkedina?

Gratulacje!

Świetny
zespół!

Sukces!



Linkedn



Będą
premie
świąteczne!

Duma z
bycia
częścią
tego
zespołu!

Copilot pozdrawia ;)

Co widzi Haker?

Format i dane na
identyfikatory
= ujawnione

Firmowy
document z
danymi



Nazwy projektów =
'Phoenix', 'Delta'

Struktura zespołu,
kluczowe osoby =
zidentyfikowane

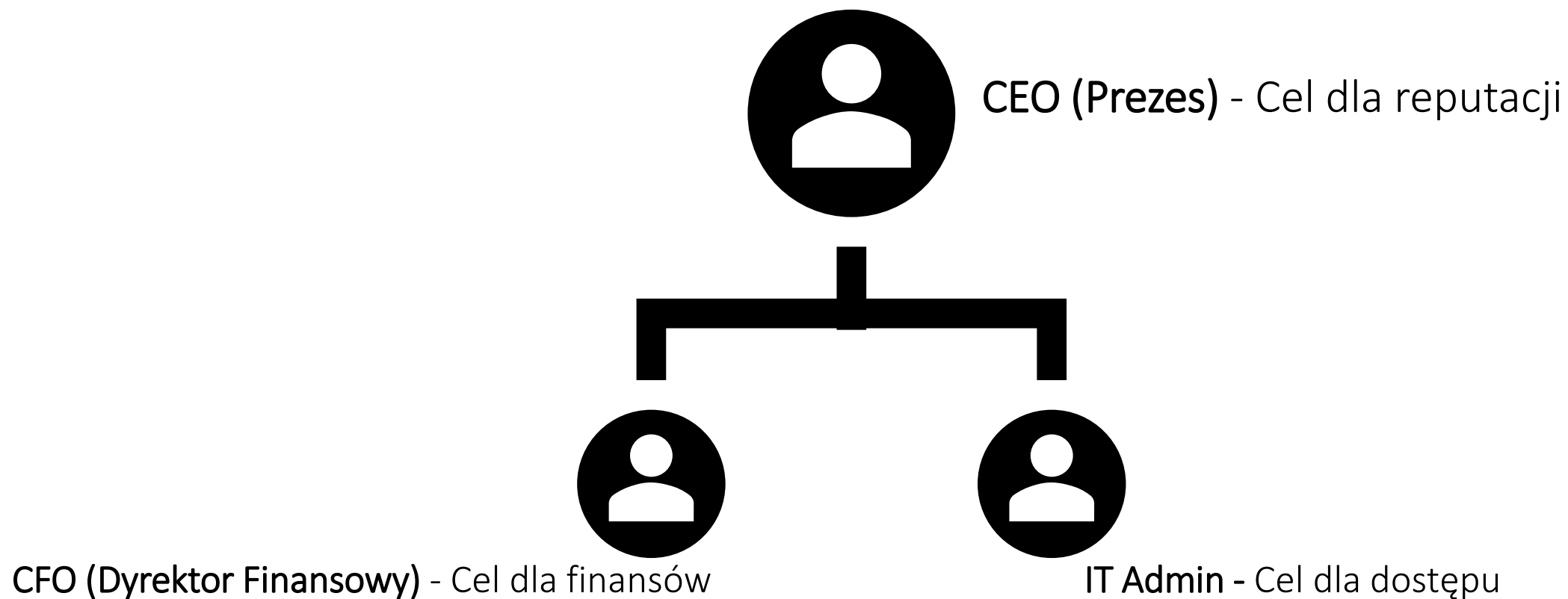
Copilot pozdrawia ;)

Mapa Infrastruktury

Subdomeny Adresy IP WordPress Chmury Fortinet

Narzędzia takie jak Shodan czy Censys pokazują Twoje 'drzwi' do internetu.

Mapa firmy



Mapa procesów

Jak pracujecie? Kto zatwierdza płatności? Kto jest Waszym dostawcą?

Odpowiedzi są w publicznych przetargach, ofertach pracy i na LinkedIn.

ZAGROŻENIE 1: ATAKI FINANSOWE



Misternie spreparowane fałszywe faktury, nie do odróżnienia od autentycznych, drenują konta.



Krok 1: Identyfikacja

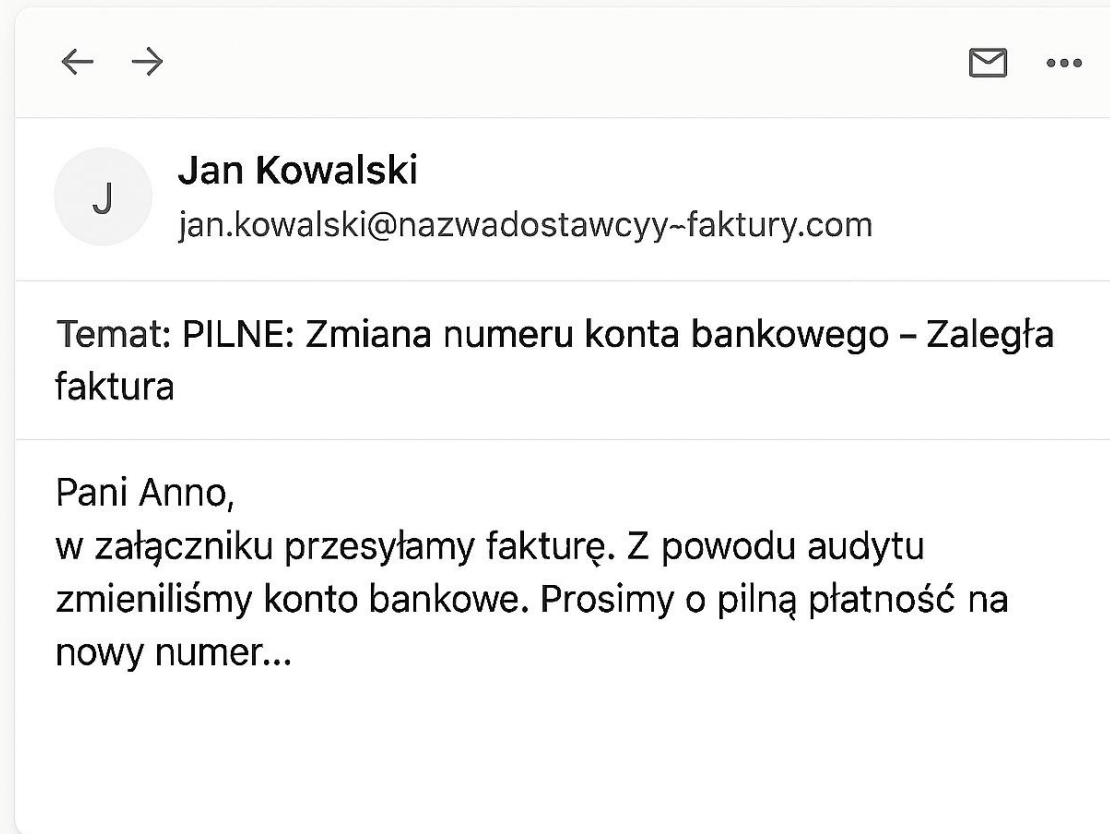
Haker znajduje Twojego dostawcę usług IT (np. z ogłoszenia o partnerstwie na Twojej stronie) oraz nazwisko Twojej Głównej Księgowej (z LinkedIn).



Krok 2: Podszywanie się

Haker rejestruje domenę nazwadostawcy-faktury.com (wygląda podobnie) i klonuje wzór Waszej faktury (znalazł ją w sieci → lub znalazła ją aplikacja AI).

Krok 3: Spear Phishing



Krok 4: Kradzież

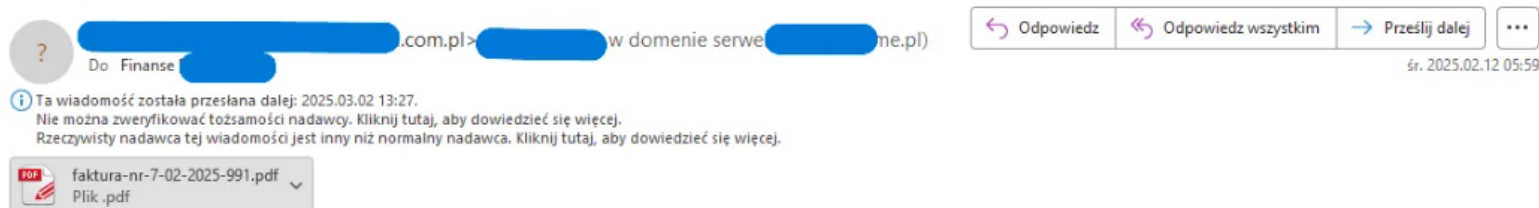
PIENIĄDZE ZNIKAJĄ. NIEODWRACALNIE.
ZAUFAŃIE ZOSTAŁO WYKORZYSTANE.



Celny atak – fałszywa faktura, która wyglądała na prawdziwą

Pewnego dnia na [skrzynkę e-mailową](#) dedykowaną do przyjmowania faktur wpłynęła wiadomość. Nadawca, na pierwszy rzut oka, był znany i zaufany – osoba z zarządu, która nadzoruje w firmie sprawy marketingowe. Treść wiadomości, załączona faktura oraz rodzaj kosztów (marketingowe) idealnie wpisywały się w typowe transakcje firmy. Co więcej, kwota na fakturze była celowo utrzymana poniżej progu 15 000 złotych, co sprawia, że transakcja nie wymaga dodatkowej weryfikacji na „białej liście” podatników VAT.

FV7/2/25



[Niektóre osoby, które odebrały tę wiadomość, nie otrzymują często wiadomości e-mail [redacted].com.pl. Dowiedz się, dlaczego jest to ważne, na stronie <https://aka.ms/LearnAboutSenderIdentification>]

W załączniku pilna faktura do opłacenia, puść ją jeszcze rano ekspresowym.

Spreparowany e-mail. Mail nadawcy składał się z prawdziwego imienia i nazwiska oraz nazwy firmy, co na pierwszy rzut oka nie budziło żadnych podejrzeń.

„Zamówienie” na cyberatak — przestępcy wysyłają fałszywe faktury

19.11.2023 11:05 mb | BANK.pl

Udostępnij



ZAGROŻENIE 2: ATAKI NA REPUTACJĘ



...podszywanie się pod inną firmę niszczy jej reputację
i zaufanie klientów.



Krok 1: Klonowanie

Haker używa OSINTu do znalezienia zdjęć Prezesa, jego stylu pisania (z postów na blogu) i kluczowych partnerów biznesowych.

Krok 2: Utworzenie Fałszywego Profilu

Prawdziwy profil



Jan Kowalski
Manager w
ABC Sp. z o.o.

linkedin.com/in/jankowalski

500+

Doświadczenie



Fałszywy profil



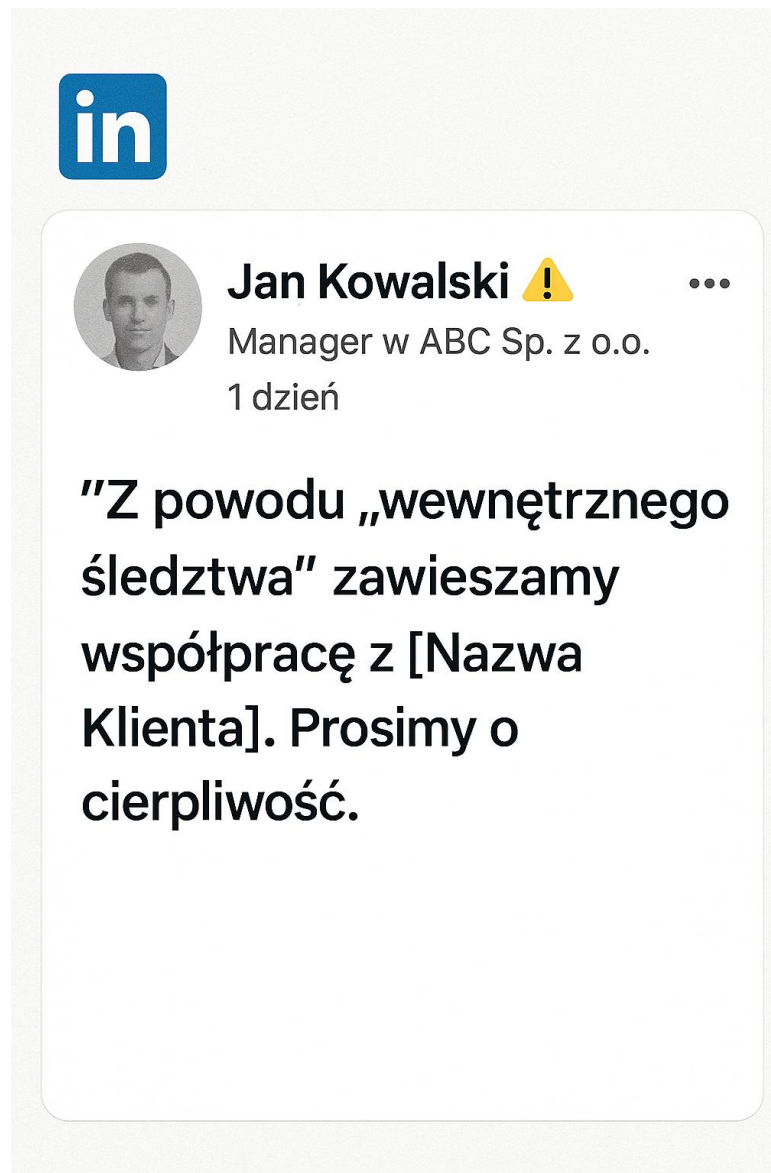
Jan Kowalski
Manager w
ABC Sp. z o.o.

linkdln.com/in/jankowalski

- niewielka liczba kontaktów
- brak szczegółowych informacji
- literówki w profilu lub URL

Haker wysyła zaproszenia do Twoich klientów i pracowników.

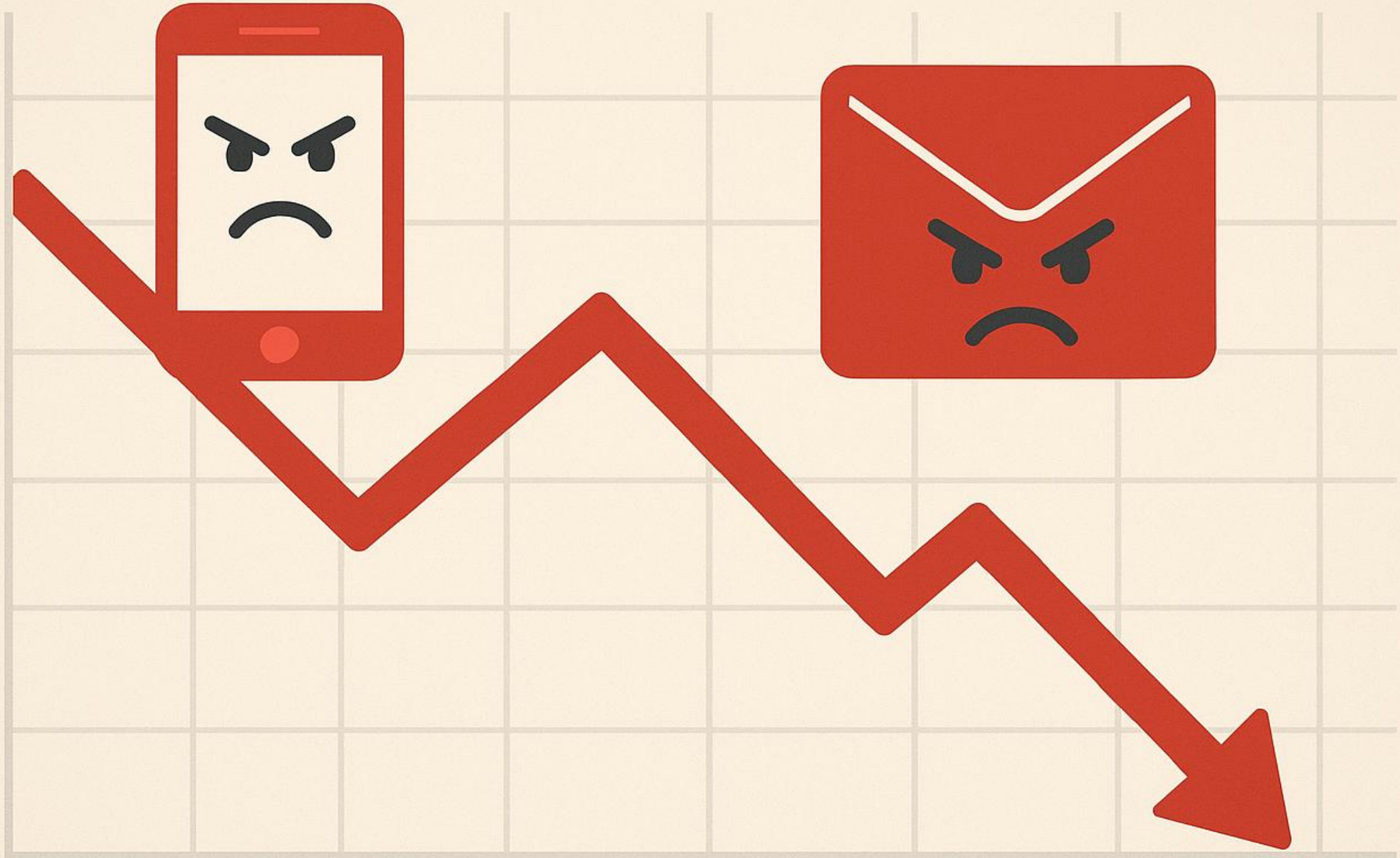
Krok 3: Atak



Z powodu 'wewnętrznego śledztwa' zawieszamy współpracę z [Nazwa Klienta]. Prosimy o cierpliwość." lub "Prywatnie uważam, że nasz nowy produkt [Nazwa] nie jest gotowy.

Krok 4: Skutek

KLIENCI PANIKUJĄ. MEDIA CYTUJĄ FAŁSZYWY
PROFIL. TRACISZ WIARYGODNOŚĆ.



Prawdziwy przypadek:
Fałszywe konto 'Eli Lilly' na Twitterze (X)
ogłosiło 'darmową insulinę'.
Akcje firmy spadły o 4.3%, tracąc
MILIARDY dolarów.



ZAGROŻENIE 3: KRADZIEŻ BEZCENNYCH DANYCH



Jak bezcenne dane są wykradane, a Twoja organizacja,
nieświadoma niczego...



Publiczny kod, prywatne klucze

HCS - Hard-Coded Credential Scanner



```
system.web
{
    //
    // Set compilation debug="true" to insert debugging
    // symbols into the compiled page. Because this
    // affects performance, set this value to true only
    // during development.
    //
    <compilation debug="true" />

    <identity impersonate="true" userName="administrator" password="PASS"/>

    <compilation debug="true">

```

Programista 'tylko na chwilę' wrzuca klucze API do publicznego repozytorium. Boty hakerów znajdują je w kilka sekund.

Co skrywa Twój PDF?

Metadane w publicznie dostępnych plikach PDF (np. raportach) ujawniają:

- Nazwiska autorów,
- Wersje oprogramowania (np. "Microsoft Word 2016" - podatne?),
- Wewnętrzne ścieżki sieciowe (np. C:\Users\JanKowalski\Desktop\Raport_Wersja_Finalna.docx)

ZAGROŽENIE 4: ATAKI SUPPLY CHAIN



...stajesz się wektorem ataków na partnerów i
kontrahentów.



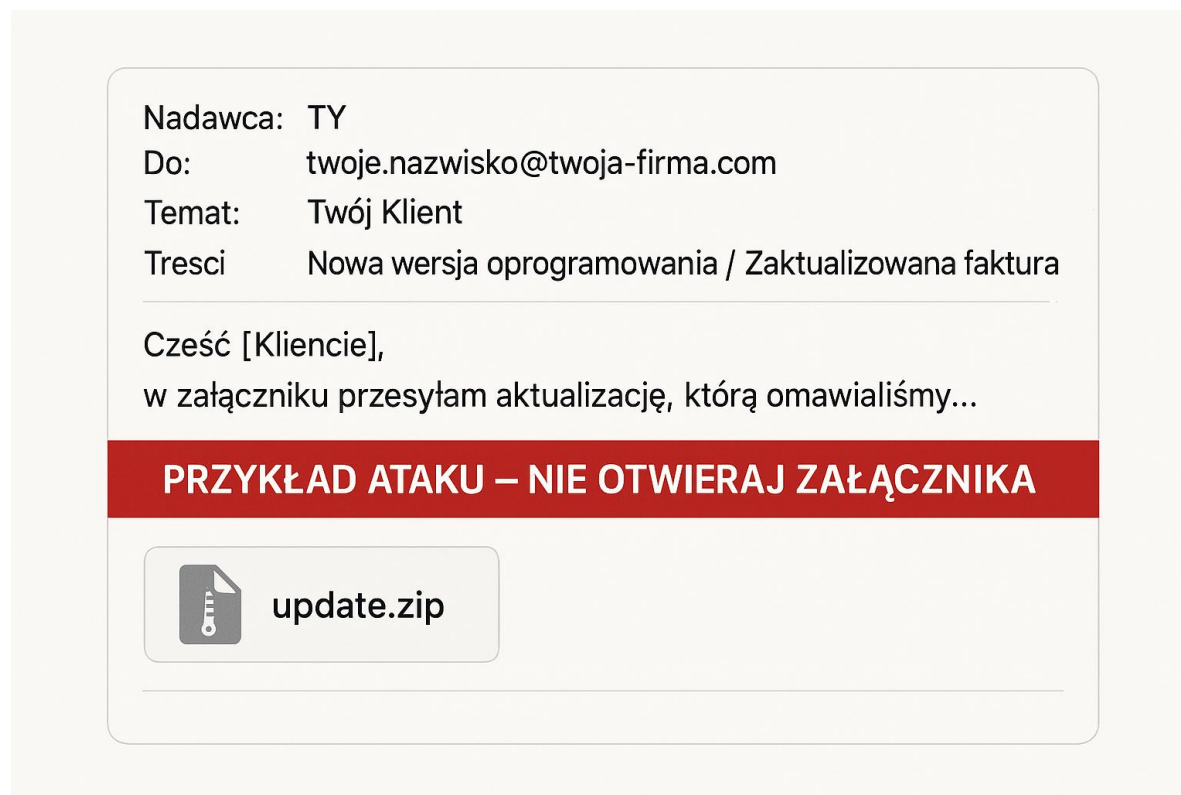
Krok 1: Jesteś celem

Haker używa OSINTu, aby znaleźć słabość w Twojej firmie. Atakuje Cię i zdobywa dostęp.

Krok 2: Jesteś bronią

Haker nie kradnie Twoich pieniędzy. On kradnie Twoje ZAUFANIE. Zdobywa dostęp do Twojej skrzynki e-mail lub systemu CRM.

Krok 3: Jesteś wektorem



Haker wysyła zaproszenia do Twoich klientów i pracowników.

Skutek: Podwójna katastrofa

Twój klient zostaje zaszyfrowany. Twoja reputacja jako bezpiecznego partnera zostaje zniszczona. Jesteś odpowiedzialny.

Luksus, na który Cię nie stać

Ignorowanie OSINTu to luksus, na który żaden biznes nie może sobie pozwolić.

Czy wiesz, co w tej chwili mówi o Twojej firmie
twoje 'zwierciadło'?



AKT III: Odwrócenie broni



Wykorzystanie narzędzi OSINT do budowania cyber-fortecy.

Przestań myśleć o OSINT jako o zagrożeniu.

Zaczynij myśleć o nim jako o swoim darmowym, stałym audycie bezpieczeństwa.



Nie możesz chronić tego, czego nie widzisz.



Zapomniane "drzwi"

Subfinder

Amass

Google Dorking
(site:*.twojafirma.com -www)

"Czy pamiętasz o test.twojafirma.com?"

"Czy dev-backup.twojafirma.com nadal działa?"

Stare, niezabezpieczone subdomeny to ulubiony wektor ataku.

Co Twoi ludzie mówią światu?

LinkedIn

Google

Hunter.io

social-searcher.com

"Czy Twoi pracownicy IT chwalą się na forach technologiami, których używacie?"

"Czy pracownicy finansów mają publicznie widoczne adresy e-mail?"

"Czy Prezes publikuje zdjęcia z wakacji... w czasie rzeczywistym?"

Czy Twoje hasła już wyciekły?

Have I Been Pwned (Domain Search)

DataDog

"Czy firmowe e-maile są w bazach danych wycieków?"

"Czy pracownicy używają tych samych haseł prywatnie i służbowo?"

Czy Twój kod "krwawi"?

GitHub Dorking

GitGuardian

(Wyszukaj na GitHub): "twojafirma.com" "api_key"

(Wyszukaj na GitHub): "internal.twojafirma.com"

Sprawdź, co Twoi programiści (lub byli programiści) trzymają w publicznych repozytoriach.

Cyfrowa higiena

Znalazłeś problemy. Czas je naprawić.

Szkolenia. Szkolenia. Szkolenia

- Polityka "Czystego biurka" i "Czystego ekranu".
- Procedura zgłaszania podejrzanych e-maili (Phishing).
- Zasady publikowania w mediach społecznościowych (Co wolno, czego nie).

Nie możesz stracić danych, których nie masz.

- Usuwać metadane z publicznych plików (PDF, DOCX).
- Wdrożyć polityki retencji danych.
- Skanuj publiczne repozytoria w poszukiwaniu wrażliwych danych.

OSINT to nie projekt. To proces

Twoja forteca potrzebuje strażników.

Ustaw alerty, które pracują dla Ciebie 24/7.

- Google Alerts (na nazwę Twojej firmy, nazwiska zarządu).
- Automatyczne skanery wycieków (np. GitGuardian).
- Usługi monitorowania DarkWebu.

Jak OSINT uratował firmę

Firma monitorująca media zauważyła rejestrację domeny nazwafirmy-support.net.

OSINT (sprawdzenie WHOIS, certyfikatów) potwierdził, że to nie oni.

Dział IT proaktywnie zablokował domenę na firewallu i wysłał ostrzeżenie do klientów, zanim rozpoczął się atak phishingowy.

To jest proaktywna obrona.

Używasz tych samych narzędzi, co haker.
Ale zamiast planować atak, znajdujesz i łatasz dziury.
Zmieniasz pole minowe w system wczesnego
ostrzegania.



Czy Twój dział IT robi to regularnie? Czy Ty to robisz?



Ignorowanie OSINTu to zaproszenie do ataku.

To luksus, na który nie możesz sobie pozwolić. Hakerzy już na Ciebie patrzą.



Musisz używać OSINTu do obrony.

To jedyny sposób, aby zobaczyć, co widzą atakujący i wyprzedzić ich o krok.



Co możesz zrobić - Strategicznie

- Zleć formalny audyt OSINT (wewnętrzny lub zewnętrzny).
- Zorganizuj szkolenie dla pracowników z "cyfrowej higieny".
- Ustaw ciągły monitoring swojego cyfrowego śladu.

Nie bój się patrzeć w zwierciadło.

Bój się nie wiedzieć, co ono pokazuje.



 nthw 

 Go to file

[📁 Partnerships](#)

[📁 Podcasts](#)

[📁 Privacy](#)

[📁 Programming](#)

[📁 Project Management](#)

[📁 Radio Frequency](#)

📁 Red Team

[📁 Active Directory](#)

[📁 Anonymity](#)

[📁 Binary PWN](#)

[📁 Blockchain](#)

[📁 C2](#)

[📁 Cloud](#)

[📁 Cracking](#)

[📁 Exploit](#)

[📁 ICS](#)

[📁 MITRE](#)

[📁 Malware](#)

[📁 Misc](#)

[📁 Mobile](#)

📁 OSINT

[📄 articles.md](#)

[📄 tools.md](#)

[📄 videos.md](#)

[NTHW](#) / [Red Team](#) / [OSINT](#) / 



 [notthehiddenwiki](#) [New Links](#)

0836d6a · 3 months ago

[🕒 History](#)

Name	Last commit message	Last commit date
 ..		
 articles.md	Links maintenance	6 months ago
 tools.md	New Links	3 months ago
 videos.md	First Release	last year

Dziękuję

Pytania? (Q&A)



Stale poszukuję nowych możliwości i ekscytujących wyzwań. Jeśli chcesz się ze mną skontaktować, proszę, skorzystaj z poniższych kanałów:



Email: info@zalnet.pl

LinkedIn: <https://www.linkedin.com/in/beatazalewa/>

Blog: <https://zalnet.pl/pl/blog/>

X: <https://x.com/beatazalewa>

GitHub: <https://github.com/beatazalewa/Conferences/>

